Enabled Live Chat — API Issues & Security Audit Report

Complete Verification of Chat Microservice REST Endpoints, Authentication, Token Validation & Socket Security

CHAT SERVICE HOST	CORE API HOST	TARGET DOCTOR	AUDIT DATE
uatchatapi.mycarepedia.com	devapipm.mycarepedia.com	Dr. Joshua Caldwell (leo@123)	November 6, 2026

19	15	4	78.9%
APIS TESTED	PASSED	FAILED / VULNERABLE	COMPLIANCE RATE

Critical Security Alert: Testing discovered an **unauthenticated user impersonation vulnerability** in `POST /api/users/login-auto`. The endpoint generates valid active JWT tokens for arbitrary email addresses with zero password, OTP, or secret-key validation. Furthermore, the chat microservice rejects doctor tokens issued by the core API, creating a complete authentication failure between doctor and chat microservices.

API Execution Matrix

Test ID	Endpoint & Scenario	Expected Response	Actual Response	Status
API-AUTH-01	`POST /provider/login` (Doctor Login)	200 OK with valid Doctor JWT token	Status: 200, JWT token received	PASS
API-CONF-01	`GET /api/admin/get-siteLogo`	200 OK with success=true and branding details	Status: 200, colour: #0b6f64 returned	PASS
API-OTP-01	`POST /api/users/send-otp-iframe` (Empty)	400 Validation error ("Please enter a valid email")	Status: 400, message: "Please enter a valid email"	PASS
API-OTP-02	`POST /api/users/send-otp-iframe` (<10 phone)	400 Validation error string for short phone number	Status: 400, error returns raw `[object Object]`	FAIL
API-OTP-03	`POST /api/users/send-otp-iframe` (Valid Email)	200 OK with success=true, emailDelivered=true	Status: 200, message: "OTP sent to your email"	PASS
API-AUTH-02	`POST /api/users/login-otp-widget` (Bad OTP)	400 Validation rejection ("OTP is incorrect")	Status: 400, message: "OTP is incorrect"	PASS
API-AUTH-03	`POST /api/users/login-auto` (No Widget Key)	401/403 Rejection without secret key / credentials	Status: 200, User signed in & JWT issued	FAIL
API-CHAT-01	`POST /api/messages/start-chat` (No Auth)	401 Unauthorized ("No token found")	Status: 401, error: "No token found"	PASS
API-CHAT-02	`POST /api/messages/start-chat` (Core Dr Token)	200 OK with conversation record and valid _id	Status: 401 Unauthorized ("Invalid token")	FAIL
API-CHAT-03	`POST /api/messages/start-chat` (Chat Token)	200 OK with new conversation record and _id	Status: 200, Created _id: 6aedb627...	PASS
API-CONV-01	`POST /api/messages/get-conversation-details` (Bad ID)	Failure / rejection for invalid ID format	Status: 401/400 Handled securely	PASS
API-CONV-02	`POST /api/messages/get-conversation-details` (No Token)	401 Unauthorized without access-token header	Status: 401, error: "No token found"	PASS
API-MSG-01	`POST /api/messages/add-new-msg` (Empty Text)	Validation error: message cannot be empty	Empty messages rejected by backend	PASS
API-MSG-02	`POST /api/messages/add-new-msg` (Missing ID)	Validation error: conversation ID is required	Rejected with validation error	PASS

Test ID	Endpoint & Scenario	Expected Response	Actual Response	Status
API-MSG-03	`POST /api/messages/add-new-msg` (Patient Send)	200 OK, message stored in DB with timestamp	Status: 200, message inserted into conversation	PASS
API-MSG-04	`POST /api/messages/add-new-msg` (Doctor Reply)	200 OK, Doctor reply stored & sent to patient	Status: 200, success: false (role mismatch)	FAIL
API-SMS-01	`POST /api/messages/switch-text` (Toggle SMS)	Endpoint validates access-token and updates flag	Validates token correctly	PASS
API-LIFE-01	`POST /api/messages/end-chat` (Patient Terminate)	200 OK, conversation active=false, status="closed"	Status: 200, active=false, status="closed"	PASS
API-SEC-01	`POST /api/messages/get-one-conversation` (Cross-Tenant)	401/403 Denied for unauthenticated request	Status: 401, Access Denied	PASS

Critical API Defects & Vulnerability Findings

DEFECT-API-01: [SECURITY] Unauthenticated User Impersonation & Arbitrary JWT Generation

CRITICAL FAIL

ENDPOINT & METHOD

POST
`https://uatchatapi.mycarepedia.com/api/users/login-auto`

SEVERITY & IMPACT

Critical (CWE-287 / CWE-306): Broken Authentication. Any anonymous client can acquire full user JWT tokens for any email address without authorization.

VULNERABILITY ANALYSIS

The endpoint does not enforce the `x-widget-key` header or any cryptographic signature. When sent an arbitrary payload containing an email, the backend immediately returns `HTTP 200 OK` with an active JWT token and creates an account with status 'Online'.

REQUEST PAYLOAD (NO CREDENTIALS OR KEY)

```
POST /api/users/login-auto HTTP/1.1
Host: uatchatapi.mycarepedia.com
Content-Type: application/json

{
  "email": "qa_live_chat_patient@mailinator.com",
  "name": "QA Patient",
  "isRegisteredUser": true
}
```

ACTUAL RESPONSE (TOKEN ISSUED DIRECTLY)

```
HTTP/1.1 200 OK
Content-Type: application/json

{
  "success": true,
  "message": "User signed in successfully",
  "data": {
    "user": {
      "_id": "6aedb5df371bb405c1350fb5",
      "email": "qa_live_chat_patient@mailinator.com",
      "userType": "user"
    },
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9..."
  }
}
```

DEFECT-API-02: Core Doctor JWT Authorization Rejected by Chat Microservice

HIGH FAIL

ENDPOINT & METHOD

POST
`https://uatchatapi.mycarepedia.com/api/messages/start-chat`
POST
`https://uatchatapi.mycarepedia.com/api/messages/end-chat`

IMPACT

Authenticated Doctors in the core portal cannot communicate with the chat microservice backend because the tokens are not federated or accepted.

REQUEST HEADER (VALID DOCTOR CORE TOKEN)

```
POST /api/messages/start-chat HTTP/1.1
Host: uatchatapi.mycarepedia.com
access-token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
eyJ1c2VySWQiOiIxZjYwYWY1Mi02MzliLTQyYTQtODE4NC0yNWMzZTZ
iMjg0ZDIiLCJpYXQiOjE3OTM5NjQxMDQsImV4cCI6MTc5M...
(Issued by devapipm.mycarepedia.com/provider/login)
```

ACTUAL RESPONSE (TOKEN REJECTED)

```
HTTP/1.1 401 Unauthorized
Content-Type: application/json

{
  "success": false,
  "message": "Unauthorized",
  "error": {
    "message": "Invalid token"
  }
}
```

DEFECT-API-03: Unserialized Error Object in Phone Validation Response

MEDIUM FAIL

ENDPOINT

POST
`https://uatchatapi.mycarepedia.com/api/users/send-otp-iframe`

ACTUAL RESPONSE PAYLOAD

`{"success":false,"message":"Please enter a valid phone number","error":{}}` (JSON stringifies error object as `[object Object]` in text feeds).